

Segurança de Dados

Objetivo da Aula

Conhecer as políticas de acesso e controle de dados, que são a espinha dorsal da segurança da informação, ao estabelecer quem tem acesso a quais dados e sob quais condições. Abordaremos métodos de criptografia que garantem a confidencialidade de dados, armazenados ou em trânsito.

Apresentação

Caro(a) aluno(a), hoje embarcaremos em uma jornada emocionante para desvendar os mistérios fundamentais da segurança da informação. Em nossa aula, exploraremos três pilares cruciais: Classificação dos Dados, Métodos de Criptografia e Políticas de Acesso e Controle.

1) **Classificação dos dados:**

- Descubra a grande importância de classificar dados com base em sua natureza e sensibilidade;
- Navegue pelas diferentes categorias, desde Dados Financeiros até Dados Sensíveis do Governo;
- Aprenda como a identificação precisa orientar a aplicação de medidas de segurança personalizadas.

2) **Métodos de criptografia:**

- Viaje pela história da criptografia, desde os primórdios até os métodos modernos;
- Mergulhe na criptografia de dados em repouso e em trânsito, compreendendo sua importância;
- Explore algoritmos, protocolos e práticas de gerenciamento de chaves que sustentam a segurança criptográfica.

3) Políticas de acesso e controle de dados:

- Entenda o princípio do “Mínimo Privilégio” e como reduz o risco de exposição de dados;
- Explore sistemas de autenticação forte, controle de acesso baseado em funções e políticas dinâmicas;
- Descubra como essas políticas são essenciais para proteger contra ameaças internas e responder a incidentes.

1. Classificação dos Dados

A classificação de dados é um componente crítico na gestão da segurança da informação, desempenhando um papel central na proteção e no controle adequado das informações sensíveis. Este processo envolve a categorização sistemática dos dados com base em sua importância, confidencialidade, integridade e disponibilidade. Vamos explorar mais a fundo a importância e os aspectos-chave da classificação de dados:

A identificação da natureza dos dados é o primeiro passo crucial no processo de classificação, sendo um processo que envolve a compreensão profunda do tipo de informação que está sendo manipulada. Cada categoria de dados possui características únicas e demanda considerações específicas de segurança.

- **Dados financeiros:**

- Este tipo de dado inclui informações relacionadas a transações financeiras, contas bancárias, números de cartões de crédito e outros detalhes financeiros sensíveis. A manipulação inadequada desses dados pode resultar em fraudes financeiras, portanto, requer medidas de segurança rigorosas.

- **Dados pessoais:**

- Informações pessoais abrangem dados identificáveis de indivíduos, como nomes, endereços, números de CPF, datas de nascimento e informações biométricas. A proteção desses dados é essencial para cumprir regulamentações de privacidade e prevenir o uso indevido.

- **Propriedade intelectual:**

- Dados relacionados à propriedade intelectual abrangem patentes, segredos comerciais, designs exclusivos e outros ativos de propriedade intelectual. A perda ou comprometimento desses dados pode ter sérias implicações para a competitividade e inovação de uma organização.

- **Dados de saúde:**
 - Informações de saúde incluem dados médicos, históricos de tratamento, registros de saúde mental, entre outros. A proteção adequada desses dados é vital para garantir a privacidade dos pacientes e cumprir regulamentações de saúde, como a HIPAA nos Estados Unidos.
- **Dados de recursos humanos:**
 - Esta categoria engloba informações sobre funcionários, como salários, avaliações de desempenho, dados de contato e registros de emprego. A segurança desses dados é crucial para proteger a privacidade dos funcionários e evitar possíveis riscos legais.
- **Dados operacionais:**
 - Dados operacionais referem-se a informações críticas para o funcionamento diário de uma organização, incluindo planos de negócios, estratégias de marketing e dados de produção. A exposição desses dados pode impactar diretamente a competitividade e a continuidade dos negócios.
- **Dados sensíveis do governo:**
 - Organizações que lidam com dados governamentais precisam classificar e proteger essas informações de acordo com as regulamentações específicas do setor público. A classificação incorreta desses dados pode resultar em violações de segurança e consequências legais.
- **Outras categorias específicas:**
 - Dependendo do setor e das atividades da organização, podem existir outras categorias específicas de dados a serem identificadas, como dados de pesquisa em instituições acadêmicas, dados de clientes em setores de varejo, entre outros.

A identificação precisa da natureza dos dados não apenas orienta a classificação, mas também influencia diretamente as decisões sobre os controles de segurança a serem implementados. Compreender os diferentes tipos de dados permite que as organizações personalizem suas abordagens de segurança, garantindo que cada categoria seja tratada de maneira apropriada para mitigar riscos específicos associados a ela.

Uma vez que o tipo de dado tenha sido identificado, é necessário determinar o nível de proteção necessário para aquele dado, pois isso permite ajustar os recursos de segurança de acordo com a importância e a sensibilidade dos dados. Essa abordagem personalizada garante que os esforços de segurança sejam direcionados de maneira eficaz, otimizando recursos e mitigando riscos proporcionalmente à criticidade dos dados.

Reconhecer que nem todos os dados possuem o mesmo valor é fundamental. A determinação do nível de proteção leva em consideração a importância estratégica, financeira ou operacional dos dados. Dados críticos para as operações essenciais de uma organização podem exigir medidas de segurança mais robustas.

A análise do impacto potencial em caso de comprometimento dos dados ajuda a estabelecer o nível de proteção necessário. Dados cuja divulgação ou alteração poderia ter consequências significativas para a organização, clientes ou partes interessadas são prioritários para medidas de segurança mais rigorosas.

A determinação do nível de proteção geralmente segue uma classificação hierárquica, onde diferentes categorias de dados recebem níveis de proteção correspondentes. Por exemplo, dados públicos podem exigir menos proteção do que dados confidenciais ou altamente confidenciais. O contexto operacional também desempenha um papel na determinação do nível de proteção. Situações específicas, como a transferência de dados entre sistemas, a comunicação com parceiros externos ou o armazenamento em nuvem, podem exigir considerações adicionais de segurança.

A determinação do nível de proteção está intrinsecamente ligada aos requisitos regulatórios. Diferentes setores e regiões possuem normativas específicas para a proteção de certos tipos de dados. As organizações precisam garantir conformidade com essas regulamentações ao definir seus padrões de segurança.

A determinação do nível de proteção não é estática, porém dinâmica. À medida que o cenário de ameaças evolui, as organizações precisam realizar avaliações contínuas de riscos para ajustar seus padrões de segurança. A implementação de medidas proporcionais à dinâmica do ambiente de ameaças é crucial.

Dados críticos muitas vezes requerem não apenas medidas preventivas, mas também estratégias robustas de recuperação em caso de incidentes. A determinação do nível de proteção deve levar em consideração não apenas a prevenção, mas também a capacidade de resposta e recuperação.

Por fim, a determinação do nível de proteção também envolve a consideração dos custos associados à implementação de medidas de segurança. Encontrar um equilíbrio entre a eficácia das medidas e a sustentabilidade financeira é essencial.

Em resumo, a determinação do nível de proteção necessário é um processo estratégico que combina avaliação de riscos, considerações operacionais e conformidade regulatória. Ao personalizar as medidas de segurança de acordo com a natureza e importância dos dados, as organizações podem criar uma postura de segurança robusta e adaptável, capaz de enfrentar desafios crescentes no cenário de ameaças digitais em constante evolução.

Além disso, os dados geralmente são classificados em categorias como público, interno, confidencial e altamente confidencial. Esta classificação de dados facilita a implementação de controles de acesso. Ao atribuir uma classificação específica a um conjunto de dados, é possível estabelecer políticas claras sobre quem tem permissão para acessar, modificar ou compartilhar essas informações.

Em muitas indústrias, a classificação de dados é crucial para cumprir regulamentações específicas de privacidade e segurança. Regulamentações, como o LGPD Brasileiro ou o GDPR da União Europeia, frequentemente exigem que as organizações classifiquem e protejam adequadamente os dados pessoais.

Por fim, a classificação facilita processos de auditoria, permitindo que as organizações monitorem o acesso e o uso dos dados de acordo com suas classificações. Isso também contribui para a responsabilização, uma vez que as ações relacionadas aos dados podem ser rastreadas e revisadas.

2. Métodos de Criptografia

A história da criptografia remonta a milhares de anos e está entrelaçada com o desenvolvimento da comunicação, os avanços tecnológicos e as necessidades de proteção de informações sensíveis. A criptografia desempenha um papel crucial na segurança da informação, fornecendo um meio eficaz de proteger a confidencialidade e a integridade dos dados. Existem diversas técnicas de criptografia aplicadas em diferentes contextos (Figura 1), como dados em repouso e dados em trânsito.

Figura 1: Mensagem criptografada na escala musical



Fonte: Junco TIC. Disponível em: <https://juncotic.com/criptografia-musical/>. Acesso em: 22 jan. 2024.

A criptografia de **dados em repouso** é uma medida essencial para proteger informações armazenadas em diversos meios, desde dispositivos físicos como laptops e smartphones até servidores, bancos de dados e ambientes de armazenamento em nuvem. A aplicação dessa técnica tem como objetivo principal impedir o acesso não autorizado a dados sensíveis, caso um dispositivo seja perdido, roubado ou acessado indevidamente.

Caso um dispositivo seja fisicamente comprometido, a criptografia garante que os dados armazenados permaneçam ilegíveis sem a chave adequada. Isso reduz significativamente o risco associado à perda ou roubo de dispositivos, proporcionando uma camada adicional de proteção.

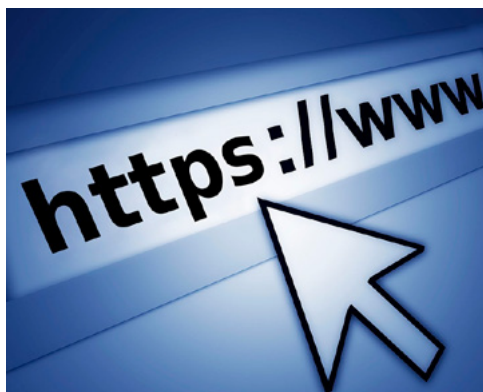
À medida que mais dados são armazenados em ambientes de nuvem, a criptografia de dados em repouso torna-se ainda mais crucial. Provedores de serviços em nuvem frequentemente oferecem opções de criptografia para garantir que os dados permaneçam seguros, mesmo quando armazenados em servidores remotos.

A criptografia também é aplicada em processos de custódia e backup de dados. Garantir que cópias de segurança estejam igualmente protegidas é fundamental para evitar a exposição de dados sensíveis, mesmo em situações de recuperação de desastres.

O gerenciamento seguro das chaves de criptografia é uma consideração crítica na criptografia de dados em repouso. Garantir que as chaves sejam armazenadas e gerenciadas adequadamente é vital para manter a segurança do sistema.

Já a criptografia de **dados em trânsito** é essencial para proteger informações durante a transmissão pela rede, seja em redes locais ou na internet. Esta forma de criptografia visa garantir que, mesmo se interceptados por terceiros maliciosos, os dados permaneçam ilegíveis.

A criptografia é fundamental para a segurança em transações online, como compras e serviços bancários pela internet. Protocolos como SSL/TLS são amplamente utilizados para criar conexões seguras entre navegadores e servidores web, protegendo informações sensíveis durante a transmissão. Protocolos de criptografia, como S/MIME (*Secure/Multipurpose Internet Mail Extensions*) e PGP (*Pretty Good Privacy*), são usados para proteger comunicações por e-mail. Isso impede que e-mails sejam lidos por terceiros durante sua transmissão.

Figura 2: Protocolo HTTPS

Fonte: Wikimedia Commons. Disponível em: <https://commons.wikimedia.org/wiki/File:Internet2.jpg>. Acesso em: 22 jan. 2024.

A criptografia é empregada em comunicações entre navegadores e aplicativos baseados na web para garantir que dados como credenciais de login e informações pessoais permaneçam seguros durante a transmissão (Figura 2).

As VPNs utilizam criptografia para criar túneis seguros através dos quais os dados são transmitidos pela internet. Isso é particularmente importante para proteger a privacidade e a segurança dos dados quando se acessa redes públicas, como Wi-Fi em locais públicos.

Durante a transmissão de dados, chaves de sessão são frequentemente utilizadas para garantir a segurança das comunicações. Essas chaves são geradas dinamicamente e são válidas apenas para a duração específica de uma sessão.

Além de proteger a confidencialidade, a criptografia em trânsito também é projetada para garantir a integridade dos dados. Isso significa que, mesmo que os dados sejam interceptados, qualquer tentativa de modificação seria detectada.

Em resumo, a criptografia desempenha um papel crítico tanto na proteção de dados armazenados quanto na segurança das comunicações online. Essas práticas são essenciais para garantir a confidencialidade e integridade dos dados em um mundo digital cada vez mais interconectado.

Existem vários algoritmos criptográficos amplamente utilizados, cada um com características específicas. Algoritmos simétricos, como AES (*Advanced Encryption Standard*), utilizam a mesma chave para criptografar e descriptografar dados. Algoritmos assimétricos, como RSA (*Rivest-Shamir-Adleman*), envolvem pares de chaves pública e privada para operações de criptografia e descriptografia. O uso de algoritmos robustos e amplamente aceitos é crucial para a segurança da criptografia.

Além da criptografia de dados, o **hashing** é uma técnica relacionada que produz uma sequência de caracteres (**hash**) fixa a partir de dados de entrada. Os **hashes** são usados para verificar a integridade dos dados. Se os dados são alterados, o **hash** resultante será diferente. No entanto, é importante observar que os algoritmos de **hashing** são unidirecionais, o que significa que não é possível reverter o processo para obter os dados originais.

Em muitas comunicações online, como mensagens instantâneas e chamadas de voz, a criptografia de ponta a ponta é empregada. Nesse modelo, os dados são criptografados no dispositivo de origem e só são descriptografados no dispositivo de destino, garantindo que ninguém intermediário tenha acesso aos dados em sua forma legível. Com certeza você já viu a mensagem no WhatsApp informando que a conversa está sendo criptografada de ponta a ponta, fazendo uma alusão a esta tecnologia de segurança de dados em trânsito (vide).



Você Sabia?

O WhatsApp utiliza criptografia de ponta a ponta para proteger suas conversas com outras pessoas. Na criptografia de ponta a ponta, as suas mensagens são protegidas por um cadeado, e apenas o destinatário e você têm a chave especial necessária para desbloqueá-lo e ler as mensagens.

Disponível em: <https://faq.whatsapp.com/820124435853543/>. Acesso em: 2 fev. 2024.

Protocolos de segurança, como SSL/TLS (**Secure Socket Layer/Transport Layer Security**), são usados para estabelecer conexões seguras na web. Eles incorporam algoritmos criptográficos para proteger a comunicação entre o navegador do usuário e o servidor web, garantindo a confidencialidade e integridade das informações transmitidas.

A aplicação adequada de técnicas de criptografia é essencial para manter a confiança e a segurança em ambientes digitais. Compreender os diferentes métodos, algoritmos e práticas de gerenciamento de chaves permite que as organizações implementem estratégias eficazes de criptografia, protegendo seus dados contra ameaças cada vez mais sofisticadas.

3. Políticas de Acesso e Controle de Dados

As políticas de acesso e controle de dados são projetadas para garantir que apenas usuários autorizados tenham acesso a dados específicos, ao mesmo tempo em que implementam medidas para monitorar e responder a atividades suspeitas. Vamos ver alguns conceitos-chave desta área:

- **Princípio do “mínimo privilégio”:**
 - O princípio do “mínimo privilégio” é uma base fundamental das políticas de acesso. Ele determina que os usuários devem ter o mínimo de acesso necessário para realizar suas funções. Isso reduz significativamente o risco de exposição de dados sensíveis, mesmo em caso de comprometimento de contas de usuário.
- **Definição de permissões:**
 - As políticas de acesso estabelecem claramente as permissões de cada usuário ou grupo de usuários. Isso inclui o acesso a sistemas, pastas, arquivos e outros recursos críticos. A revisão periódica e a atualização das permissões são práticas essenciais.
- **Sistemas de autenticação forte:**
 - Além de senhas, a autenticação forte é frequentemente implementada para aumentar a segurança. A autenticação de dois fatores (2FA) ou autenticação multifatorial (MFA) exige que os usuários forneçam mais de uma forma de identificação, adicionando uma camada adicional de segurança.
- **Controle de Acesso Baseado em Funções (RBAC):**
 - O RBAC é uma abordagem que associa permissões de acesso a funções específicas dentro da organização. Isso simplifica a administração, garantindo que as permissões se alinhem de forma lógica com as responsabilidades dos usuários.
- **Monitoramento e auditoria:**
 - A implementação de sistemas de monitoramento e auditoria é essencial. Essas ferramentas registram atividades de usuários, permitindo a identificação de padrões normais e a detecção de comportamentos suspeitos. A auditoria é crucial para a conformidade regulatória e investigação de incidentes.
- **Proteção contra ameaças internas:**
 - Políticas de controle de dados visam mitigar ameaças internas, reconhecendo que não apenas usuários externos representam riscos. A monitoração de atividades, juntamente com a revisão regular de permissões, ajuda a identificar comportamentos potencialmente maliciosos de dentro da organização.

- **Criptografia de dados:**

- Além do controle de acesso, a criptografia é frequentemente aplicada como uma medida adicional para proteger dados sensíveis. Mesmo que um usuário tenha acesso autorizado, os dados permanecem cifrados e ininteligíveis sem a chave adequada.

- **Políticas dinâmicas:**

- As políticas de acesso e controle de dados não são estáticas. Elas devem ser dinâmicas e adaptáveis, ajustando-se conforme as mudanças nas operações, na estrutura organizacional e nas ameaças cibernéticas. Isso inclui a revogação rápida de acessos para usuários que mudaram de função ou deixaram a organização.

- **Treinamento e conscientização:**

- A implementação eficaz das políticas de acesso requer treinamento contínuo e conscientização dos usuários. Isso inclui a compreensão das políticas, a importância da segurança da informação e práticas seguras para proteger dados.

- **Resposta a incidentes:**

- As políticas também devem abordar procedimentos para resposta a incidentes. Isso inclui a identificação rápida de violações de segurança, a contenção de danos e a recuperação dos sistemas afetados.

Podemos então concluir que as políticas de acesso e controle de dados são pilares fundamentais na estratégia de segurança da informação de uma organização. Ao estabelecer limites claros, implementar medidas de monitoramento eficazes e garantir a conformidade com regulamentações, as organizações podem reduzir significativamente os riscos associados ao acesso não autorizado e proteger seus ativos de informação mais críticos.

Considerações Finais da Aula

Em um cenário onde a informação é um ativo valioso e os desafios cibernéticos são crescentes, a adoção de práticas robustas de segurança da informação é imperativa. A classificação adequada dos dados, a aplicação de métodos eficazes de criptografia e a implementação de políticas de acesso e controle são peças cruciais desse quebra-cabeça.

A Classificação de Dados não apenas fornece uma estrutura para entender a natureza dos dados, mas também orienta a implementação de medidas proporcionais à sua importância. A determinação do Nível de Proteção Necessário assegura que os recursos de segurança sejam alocados de maneira eficaz, considerando a dinâmica do ambiente de ameaças.

Os Métodos de Criptografia são essenciais para garantir a confidencialidade dos dados em repouso e em trânsito. Desde a criptografia simétrica até protocolos de segurança em comunicações online, a criptografia é uma barreira vital contra ameaças cibernéticas.

As políticas de acesso e controle de dados são a espinha dorsal da segurança da informação. Ao estabelecer quem tem acesso a quais dados e sob quais condições, essas políticas não apenas previnem o acesso não autorizado, mas também contribuem para a identificação precoce de comportamentos suspeitos.

Em conjunto, esses pilares criam uma postura de segurança abrangente, adaptável e eficaz. Reconhecendo que a segurança da informação é um esforço contínuo, a compreensão desses elementos e a sua aplicação prática capacitam as organizações a enfrentar os desafios em constante evolução do mundo digital. A proteção da informação é mais do que uma necessidade operacional; é uma responsabilidade que define a confiança e a credibilidade em um ambiente digital interconectado.

Materiais Complementares

Artigo

Classificação de dados na LGPD

2024, ADDIT.

Apresenta a classificação de dados na LGPD.

Disponível em: <https://addit.com.br/classificacao-de-dados-na-lgpd/#:~:text=A%20classifica%C3%A7%C3%A3o%20de%20dados%20%C3%A9%20o%20processo%20de%20analisar%20dados,%2C%20sens%C3%ADveis%2C%20p%C3%ABlicos%20e%20anonimizados>. Acesso em: 2 fev. 2024.

Vídeo

Classificação de Dados

2020, Prof. Palazzo.

Apresenta conceitos de classificação de dados.

Disponível em: <https://www.youtube.com/watch?v=HsslemcqsGg>. Acesso em: 2 fev. 2024.

Referências

POLÍTICA de acesso: entenda a importância e saiba como fazer. **Fsense**, 2023. Disponível em: <https://fsense.com/pt/politica-de-acesso-importancia-como-fazer/>. Acesso em: 14 ago. 2023.

SECRETARIA de Governo Digital. **Programa de privacidade e segurança da informação (PPSI)**. 2023. Disponível em: https://www.gov.br/governodigital/pt-br/seguranca-e-protecao-de-dados/ppsi/modelo_politica_controle_acesso.pdf. Acesso em: 14 ago. 2023.